Seawolf - informe-auditoria-dooplay-20261025

INFORME DE AUDITORÍA — DooPlay 2.5.4 “NJ” (nulled)

Para: Monarca (Key) · **De:** Bellion, Gran Comandante · **Fecha:** 2026-10-25 **Objeto:** `dooplay-2.5.4-NJ.zip` (8,3 MB · 624 archivos · 277 PHP · 21,4 MB expandido)
Procedimiento: `untrusted-code-audit` (estático, sin ejecutar el objetivo)

---

1. VEREDICTO

> **NO se encontró huella conocida de puerta trasera.**

Con la salvedad honesta que manda la doctrina: *“no backdoor encontrado” ≠ “limpio”*. Falta la prueba definitiva — **un diff contra el DooPlay 2.5.4 oficial**, que no tenemos. Lo que afirmo: **no aparece ninguna de las formas conocidas.** Lo que NO afirmo: pureza absoluta.

---

2. ORIGEN (identificado, sin ambigüedad)

`License key.txt` dice textualmente: > *“License key: To get license key visit **https://nulljungle.com**”* > *“Use the license key you have received from NullJungle to activate both theme and dbmovies.”*

→ **Copia NULLED de NullJungle.** El código pudo ser modificado por el reempaquetador.

---

3. RASTRO DE EVIDENCIA (lo que se revisó)

3.1 Inventario

Hallazgo	Lectura
624 archivos (277 PHP)	normal para el tema
`dooplay/` (617) + `dooplay-child/` (5)	estructura estándar
`logo.zip` anidado (40 KB)	**inspeccionado**: solo `Logo/` (png, psd, ttf) → **limpio**
`Thumbs.db` ×3	artefactos de Windows → el zip fue **reempaquetado en un escritorio** (señal débil de manipulación)
`jwplayer.flash.swf`	parte histórica de JWPlayer (tema de 2021), no ejecutable en servidor

3.2 Escaneo de firmas (276 PHP)

Patrón	Hits	Triaje
`eval` / `assert` / `create_function`	**0**	✅
`base64_decode` literal	**0**	✅
`system`/`shell_exec`/`passthru`/`popen`	**0**	✅
`fsockopen` / socket directo	**0**	✅
Puerta por hash `md5($_GET…)`	**0**	✅ firma clásica AUSENTE
Puerta por cabecera `$_SERVER['HTTP_…']`	**0**	✅
IPs literales / llamadas a IP	**0**	✅
`file_put_contents` a URL remota	**0**	✅
`include`/`require` con superglobal	**0**	✅
Cadenas `chr()` encadenadas	**0**	✅
Base64 largo embebido	**0**	✅
`str_rot13`	**0**	✅
`call_user_func`	24	—
`file_put_contents`	4	—
`wp_mail`/`curl_init`	4	—

Triaje de los no-cero: - `call_user_func` → **Codestar Framework** (marco de opciones legítimo) + el candado de licencia. - `file_put_contents` → caché de plantilla (`doo_cache.php`), caché de `dbmvs`, y **descarga de Google Drive** (función propia). - `wp_mail` → **formularios de contacto** (`inboxes.php`, `requests.php`). - `curl_init` → integración **Google Drive**.

3.3 El "payload" ofuscado — DESCIFRADO

`inc/doo_init.php:177`:

```
$code1 = unserialize(gzuncompress(stripslashes(call_user_func('base'.$codex.'_decode',
         rtrim(strtr('eNortjK0tFJKyc8vyEmsjM_JTE7NK06Nz06tVLIGXDCDiAmz','-
         _','+/'),'='))))));
```

Nombre de función armado por partes (`'base'.$codex.'_decode'`) → evade un grep de `base64_decode`.

Descifrado paso a paso: `strtr('-_'→'+/')` → base64 → zlib → **resultado**:

```
s:19:"dooplay_license_key";
```

→ **Es el NOMBRE DE LA OPCIÓN DE LICENCIA de WordPress.** Es decir: **la protección anti-pirata del propio autor de Doothemes**, no un backdoor.

3.4 El "null" — localizado y clasificado

`inc/doo_database.php:209`:

```
case 'forcelicense':
    update_option('dooplay_license_key_status','valid');
```

Clasificación por ALCANCE (no por existencia):

```
if(is_admin()){ ... }                                    // exige admin
if($run && wp_verify_nonce($noc,'doodatabasetoolnonce')) // exige nonce
```

→ **Es un CRACK, no un backdoor.** Está detrás de **capability + nonce**; no es alcanzable sin autenticación. Vive junto a las herramientas legítimas (`genpages`, `transients`, `reports`, `ratings`).

3.5 Fechas

Todas 2021-06-10/11 → **coherentes**. Ningún archivo con fecha suelta de otra época.

3.6 Validación de licencia (legítima)

`inc/core/doothemes/class.php` → clase EDD estándar: `wp_remote_get` a la URL remota con `edd_action=activate_license`. **Sin IPs, sin dominios ocultos, sin exfiltración.**

---

4. HALLAZGO COLATERAL (más grave que el tema)

🔴 **Credencial en texto plano**: el bloque MCP `wp-streaming` de `config.yaml` contiene `WORDPRESS_APP_PASSWORD` **en claro** para `kmoviezone.net` (valor omitido por política). **Viola la doctrina de secretos.** Remedio: mover a `.env` (`${VAR}`) **y rotar**.

---

5. LÍMITES DE ESTA AUDITORÍA (declaración honesta)

1. **Análisis estático de patrones.** No se observó ejecución (runtime).
2. **Sin diff contra el original.** La prueba concluyente sería comparar con el DooPlay 2.5.4 oficial.
3. Los bundles de terceros (**Codestar**, **dbmvs**) se revisaron por firmas, no línea por línea.
4. **Un tema limpio puede comprometerse después** por un plugin vulnerable o un admin robado.

---

6. CONCLUSIÓN

El zip no presenta puerta trasera conocida. Contiene el crack de licencia (`forcelicense`, admin+nonce) y la ofuscación anti-pirata del autor original. **El riesgo principal NO es el tema: es que (a) es nulled y no se actualiza, y (b) dejamos una credencial en texto plano en nuestra propia configuración.**

Decisión estratégica: reconstruir kmoviezone **sin WordPress y sin PHP** (clean-room, desde el mapa de funciones) → el problema desaparece por diseño.

— Bellion, Gran Comandante del Ejército de Sombras